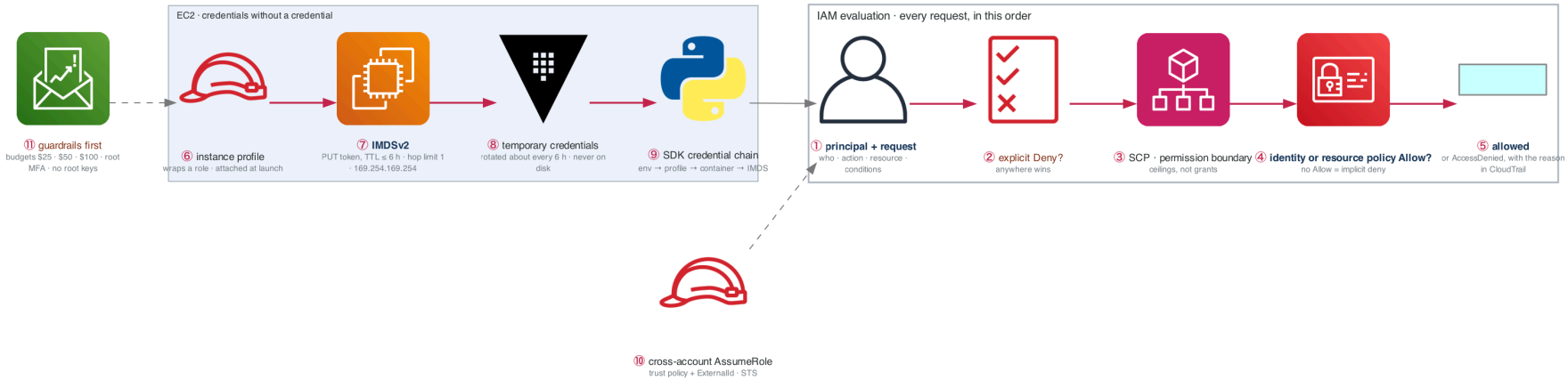
How AWS decides, and how an instance gets credentials with no keys on disk, numbered

Week 5 · Figure 5.1 · figure with badges 1–11 · 2026-10-17



What to say, badge by badge

About three and a half minutes at a normal pace (440 words). Point at each badge as you say its line.

Open
“IAM breaks in production more than anything else in AWS. The top row is the decision AWS makes on every call. The bottom row is how a machine gets to make calls at all, without a key on disk. Both are exam material and both are interview material.”

1 principal and request
“A principal, an action, a resource, and conditions. Every AccessDenied is one of those four being different from what you assumed. The policy simulator lets you test the four without making the call.”

2 explicit Deny
“An explicit Deny anywhere wins, over any Allow, from any policy. This is the first thing evaluated and the first thing to look for when a user with AdministratorAccess still gets denied.”

3 SCP and permission boundary
“These are ceilings. An SCP from Organizations and a permission boundary on the identity can only take permissions away. A boundary that does not mention S3 means no S3, however generous the identity policy is.”

4 identity or resource policy Allow
“Within the same account, an Allow from either the identity's policy or the resource's policy is enough. Across accounts, you need both. No Allow at all is an implicit deny, and it is the common case.”

5 allowed
“Or denied, and the reason is in CloudTrail. Four AccessDenied stories become blog post 3.”

6 instance profile
“A role needs a vehicle to ride on an instance. The instance profile is that vehicle, attached at launch. The role has the permissions; the profile is just the attachment.”

7 IMDSv2
“The instance asks the metadata service at 169.254.169.254. Version 2 requires a PUT to get a session token first, with a TTL up to six hours, and a hop limit of one so a container on the instance cannot reach it. Version 1 is a plain GET, and that is the SSRF story.”

8 temporary credentials
“The answer is an access key, a secret, and a session token, rotated roughly every six hours. Nothing is written to disk. Lose the instance, lose the credentials.”

9 SDK credential chain
“The SDK looks in order: environment variables, a profile file, the container endpoint, then IMDS. Knowing the order explains why a stray key in a profile file silently overrides the role.”

10 cross-account AssumeRole
“A role in account B trusts a principal in account A. STS issues temporary credentials. ExternalId stops the confused-deputy problem when a third party does the assuming.”

11 guardrails first
“Before any of this exists: three budgets, alerts tested, MFA on root, root access keys deleted. The script does the budgets. The rest is a five-minute console task you do once.”

Close
“Deny first, ceilings next, then an Allow or nothing. And a machine earns credentials by being who it is, not by holding a key. Week 12 and week 16 are the same idea for a GitHub workflow and for a pod.”